

MODULO 3

***PRÁCTICA N3->**

“Inyección de SQL”

1. Introducción y Conceptos

La inyección SQL es una técnica de inyección de código que explota una vulnerabilidad de seguridad en un sitio web o en el software de una aplicación. Los ataques utilizan consultas o declaraciones SQL maliciosas para manipular directamente cualquier tipo de base de datos SQL. Estas vulnerabilidades ocurren

cuando las aplicaciones no validan correctamente la entrada antes de pasarla a una instrucción SQL.

2. Técnica 1: Detección con DSSS

Siguiendo las directrices de la práctica, se procedió a auditar el sitio mediante Damn Small SQLi Scanner (DSSS).

Procedimiento: Se ejecutó la herramienta sobre el parámetro id de la URL objetivo.

Resultado: DSSS confirmó que el parámetro id parece ser vulnerable a Blind SQLi (Inyección SQL Ciega).

Evidencia: El escáner detectó que la aplicación responde a consultas manipuladas (ej: AND 210=210), confirmando que se puede interactuar con la base de datos a través de la entrada del usuario.

```
(kali@kali)-[~/DSSS]
$ python3 dsss.py -u "http://www.tokiohacking.com/index.php?id=1"
Damn Small SQLi Scanner (DSSS) < 100 LoC (Lines of Code) #v0.3b
by: Miroslav Stampar (@stamparm)

* scanning GET parameter 'id'
(i) GET parameter 'id' appears to be blind SQLi vulnerable (e.g.: 'http://www.tokiohacking.com/index.php?id=1
%29%2F%2A%2A%2FAND%2F%2A%2A%2F210%3D210')

scan results: possible vulnerabilities found
```

3. Técnica 2: Detección con OWASP ZAP

Siguiendo la segunda directriz, se utilizó OWASP ZAP para auditar el sitio en busca de vulnerabilidades de inyección SQL.

Procedimiento: Se realizó un escaneo automatizado sobre la web <http://www.tokiohacking.com/> para identificar debilidades en la autenticación de usuarios y validación de niveles de acceso.

Resultado: Aunque ZAP identificó múltiples fallos de seguridad (como falta de tokens Anti-CSRF y librerías vulnerables), la auditoría se centró en la estructura del software para detectar posibles puntos de inyección.

Evidencia: Se analizó la superficie de ataque, confirmando que la falta de validación de entradas es el factor común que permite este tipo de ataques

devastadores para tomar el control de sitios web.

